SIGPN-T — Revue indépendante des spécifications biométriques version 1.1

Police nationale du Tchad — Éditeur : TECHNOTCHAD — 11 novembre 2026 — Revue adverse, en lecture seule

Rubrique	Valeur
Document examiné	`docs/biometrie/SPEC_EVOLUTION_BIOMETRIQUE_V1.1.md` (commit `31adc24`, 25 pages)
Mode	**Lecture seule et documentation uniquement.** Aucun code, aucune migration, aucune donnée ni configuration modifiés ; marqueurs DEMO intacts ; aucun commit poussé
Principe de la revue	**Une correction documentée n'est pas une correction validée.** Chaque affirmation de la version 1.1 a été confrontée au code, au schéma, aux migrations, aux tests et au déploiement ; les contradictions internes ont été recherchées
Verdict	**NON VALIDÉ en l'état pour autorisation d'implémentation** (30 anomalies : 2 critiques, 14 majeures, 12 moyennes, 2 mineures)

1. Limites de cette revue (à lire d'abord)
2. Verdict global et synthèse par axe
3. Ce qui a été vérifié dans le code (preuves)
4. VALIDÉ p. 2
5. VALIDÉ SOUS RÉSERVE p. 3
6. NON VALIDÉ p. 3
7. DÉCISION DE LA DIRECTION REQUISE p. 4
8. Revue des 16 décisions p. 5
9. Checklist de revue indépendante recommandée (remplace les 14 points de l'auteur) p. 5
10. Revue des 10 risques résiduels p. 6
11. Suite recommandée p. 6
12. Annexe — Détail des anomalies restantes p. 7

1. Limites de cette revue (à lire d'abord)

1. **L'indépendance est de procédure, pas d'organisation.** Cette revue est conduite par le même assistant que celui qui a rédigé la version 1.1, dans la même lignée de travail. J'ai cherché à la rendre adverse (hypothèse : chaque correction est fausse jusqu'à preuve du contraire) et à tout vérifier dans le code, mais **elle ne remplace pas une revue humaine externe** (architecte sécurité, responsable de la protection des données, juriste). Elle doit être traitée comme une **entrée** de cette revue, non comme sa conclusion.
2. Trois requêtes **de lecture seule** (`SELECT`, transaction en lecture seule) ont été faites sur la base de développement pour vérifier les propriétaires de tables, les déclencheurs et le rôle de connexion. Rien n'a été écrit.
3. Aucune information sur un fournisseur précis, sur le Dossier unique national ni sur les textes juridiques tchadiens n'a été consultée.

2. Verdict global et synthèse par axe

La version 1.1 corrige réellement plusieurs défauts de la 1.0 (notamment la régression sur l'authentification à deux facteurs et la séparation des administrateurs verrouillés), mais elle laisse subsister des failles de fond sur l'inviolabilité, la séparation des fonctions et la planification des phases. Elle ne doit pas être autorisée à l'implémentation avant une version 1.2.

Axe demandé	Statut	Anomalies principales
1. Inviolabilité de l'historique, y compris face aux administrateurs privilégiés	**NON VALIDÉ**	A-01, A-02, A-04, A-05 ; réserves A-03, A-06, A-07
2. Portabilité réelle des gabarits entre fournisseurs AFIS	**NON VALIDÉ** (ordre de la procédure) · **VALIDÉ SOUS RÉSERVE** (modèle de données) · **DÉCISION REQUISE** (D-03)	A-08 ; réserves A-09, A-10
3. Sécurité du coffre et cycle de vie des clés HSM	**NON VALIDÉ** (architecture du coffre)	A-11 ; réserves A-12, A-13
4. Conservation des échantillons de référence	**NON VALIDÉ** (modèle) · **DÉCISION REQUISE**	A-14 ; A-15, A-16

TECHNOTCHAD

5. Fédération avec le Dossier unique national	**VALIDÉ SOUS RÉSERVE** · **DÉCISION REQUISE**	A-17 ; réserve A-18
6. Séparation des responsabilités et 29 rôles existants	**NON VALIDÉ** (séparation de personne, épinglage des droits) · **VALIDÉ** (préservation des 29 rôles)	A-19, A-20 ; réserve A-21
7. Compatibilité des 158 droits existants	**VALIDÉ SOUS RÉSERVE**	A-22
8. Critères de sortie et de retour arrière des neuf phases	**NON VALIDÉ** (critères non mesurables, collecte non planifiée)	A-23, A-24 ; réserve A-25
9. Les 16 décisions de la Direction	**VALIDÉ SOUS RÉSERVE** · **DÉCISIONS MANQUANTES**	A-27
10. Les 14 points de contrôle et les 10 risques résiduels	**NON VALIDÉ** (incomplets, auto-évalués)	A-28, A-29

Bilan des 30 anomalies par statut : NON VALIDÉ **11** · VALIDÉ SOUS RÉSERVE **15** · DÉCISION DE LA DIRECTION REQUISE **4**.

3. Ce qui a été vérifié dans le code (preuves)

Vérification	Résultat	Conséquence
Propriétaire des tables `AuditLog`, `BiometricSearch`, `BiometricControl`, `CustodyEvent`	**`pms_app`**	Le compte de l'application possède les tables
Droits du compte de connexion (base de développement)	**superutilisateur PostgreSQL et créateur de rôles**	Il peut désactiver un déclencheur ou modifier les tables sans restriction
Déploiement de production (`deploy/docker-compose.yml`)	`POSTGRES_USER` par défaut **`pms_app`**, utilisé aussi dans `DATABASE_URL` de l'application	Dans l'image officielle, cet utilisateur est **le superutilisateur du cluster** ; l'application se connecte donc avec lui
Déclencheurs d'écriture seule existants	**Seulement** `audit_log_append_only`, `audit_log_chain`, `custody_event_append_only`	`BiometricSearch`, `BiometricMatch`, `BiometricControl` n'ont **aucun** déclencheur (confirme C-02 de la revue précédente)
Chaîne de hachage	Sur `AuditLog` uniquement	Les tables biométriques ne sont pas chaînées
Restauration	`deploy/backup/restore.sh` ; droit `system:backup` détenu par l'administrateur technique	Une restauration peut ramener la base à un état antérieur
Rôles par compte	`User.roleId` : **un seul rôle par compte** ; `Officer.userId` unique mais facultatif	La « règle de non-cumul » de la v1.1 est sans effet sur des comptes ; le risque est une même personne avec deux comptes
Éligibilité des approbateurs	`approvals/rules.ts` : seulement `approvals:decide`	Les commandements et l'administrateur de la police décideraient de tout nouveau type d'approbation sans restriction explicite
Secrets TOTP chiffrés avec `crypto.ts`	`auth/login.ts` lignes 100, 198, 205, 231	Confirme que ne **pas** modifier `crypto.ts` est correct
Test de séparation des administrateurs	`tests/unit/admin-separation.test.ts` compare les droits à l'identique	Confirme que ne **pas** modifier les deux rôles verrouillés est correct

4. VALIDÉ

Points vérifiés et jugés corrects, sans réserve bloquante.

N°	Point validé	Vérification
V-01	**`crypto.ts` et `auth/login.ts` ne sont pas modifiés** ; coffre séparé avec format versionné	Les secrets MFA utilisent bien ces fonctions ; la solution évite la régression
V-02	**Les rôles `SUPER_ADMIN` et `SECURITY_ADMIN` restent inchangés** ; le test de séparation continue de s'appliquer	Test unitaire vérifié
V-03	**Aucun droit n'est retiré à aucun des 29 rôles** ; aucun des 158 droits n'est renommé ou supprimé	Principe additif cohérent avec le catalogue réel
V-04	**Étanchéité DEMO / réel** : tables DEMO inchangées et verrouillées par `DEMO_SHA256`, nouveau modèle séparé, plafond de mode	Cohérent avec la structure actuelle (tables de gabarits indépendantes)
V-05	**Aucune décision automatique** : valeurs `NO_CANDIDATE`, `REVIEW_REQUIRED`, `UNAVAILABLE` ; « indisponible » jamais lu comme « aucune correspondance »	Cohérent avec le comportement actuel
V-06	**Interdiction du SHA-256 comme gabarit** et rejet par les adaptateurs réels	Cohérent avec l'état du simulateur

TECHNOTCHAD

V-07	**Phases 0 et 1 sans donnée biométrique réelle** (déclarées comme telles)	Cohérent
V-08	**Le principe de fédération** (pas d'échange de gabarits par défaut ; identifiant de sujet stable ; liens et événements)	Résout correctement le défaut de `mergePersons` (aucun enregistrement biométrique déplacé)
V-09	**Les routes existantes restent compatibles** (enveloppes minces, contrats inchangés)	Cohérent avec `withApi` et les 12 routes
V-10	**Le plan de tests existants à conserver** est complet et exact (fichiers vérifiés)	Chemins vérifiés

5. VALIDÉ SOUS RÉSERVE

N°	Élément	Condition pour lever la réserve
A-03	Empreinte de tête exportée quotidiennement	Préciser le support externe immuable, la fréquence, le vérificateur
A-06	Colonnes immuables des tables d'historique	Liste exhaustive incluant `isDemo` ; `requestedById` non nul pour les lignes réelles
A-07	`BiometricControl` et décision unique	Champs de décision du contrôle en lecture seule dans le chemin réel
A-09	Portabilité testée entre deux simulateurs seulement	Essai avec un second moteur réel ; seuil de dégradation toléré
A-12	Double contrôle des clés défini dans l'application	Quorum natif du HSM, séparation des rôles HSM
A-13	Cycle de vie des clés incomplet ; chiffrement sans données authentifiées associées	Chapitre complet ; liaison AAD obligatoire
A-16	Sauvegardes à 35 jours	Sauvegarde dédiée aux gabarits ; exclusion des autres sauvegardes
A-18	Fédération : flux, scissions, pseudonymes, mode dégradé	Matrice de flux et procédure de scission
A-21	Attribution des profils de gouvernance	Attribution réservée à une demande approuvée par commandement national + DPO
A-22	Droits existants	Liste des tests à adapter ; contrat de réponse versionné pour la scission de visibilité
A-25	Retour arrière des migrations	Stratégie « avancer seulement » pour les énumérations ; retour par désactivation
A-26	Biais d'automatisation de la revue humaine	Revue en aveugle, échantillons-pièges, filigrane, indicateurs
A-28	Registre des risques	Version complète et recotée
A-29	Checklist de 14 points	Remplacée par la checklist de la section 9
A-30	Imprécisions diverses	Corrections rédactionnelles

6. NON VALIDÉ

6.1 Anomalies critiques

N°	Anomalie	Impact	Correction recommandée
A-01	**Le compte de l'application est propriétaire des tables et superutilisateur de la base** (vérifié en développement ; le déploiement de production utilise le même identifiant pour la base et l'application). La v1.1 invoque des « rôles de base séparés » qui **n'existent pas**	Les déclencheurs d'écriture seule peuvent être désactivés par l'application elle-même, par quiconque obtient ses accès ou par un administrateur disposant du mot de passe : **l'inviolabilité affirmée n'existe pas face aux privilégiés**	Prérequis de la phase 1 : **séparer les rôles PostgreSQL** (propriétaire des migrations ≠ rôle applicatif ; le rôle applicatif sans DDL, sans superutilisateur, sans droit de désactiver un déclencheur ; `REVOKE UPDATE, DELETE` sur les tables en écriture seule) ; migrations exécutées par un rôle distinct au déploiement ; surveillance des modifications de schéma. Composants : `deploy/docker-compose.yml`, `deploy/entrypoint.sh`, scripts de sauvegarde
A-02	**Aucune chaîne de hachage sur les tables biométriques** ; la v1.1 ne demande même pas que le contenu de chaque décision soit inscrit dans le journal chaîné	Une altération par un privilégié est **indétectable** : le journal chaîné atteste « une revue a eu lieu » mais pas son contenu	Inscrire dans `AuditLog` (chaîné) l'**empreinte canonique** de chaque ligne de `BiometricSearch`, `BiometricMatch`, `BiometricReview` à la création ; contrôle périodique de concordance ; alerte en cas d'écart

6.2 Anomalies non validées (13 majeures et A-14, moyenne)

N°	Anomalie	Impact	Correction recommandée

TEXTE NON OFFICIEL

A-04	**La restauration d'une sauvegarde est un vecteur de falsification** : l'administrateur technique détient `system:backup` et un script de restauration existe ; la v1.1 ne prévoit ni double contrôle, ni vérification avant remise en service	Retour à un état antérieur : effacement des revues récentes, résurrection de gabarits effacés	Restauration **à double contrôle** ; vérification automatique de la chaîne **et des empreintes externes** avant remise en service ; journal externe de toute restauration
A-05	**Le registre d'effacement est une table de la base** : une restauration antérieure à son inscription le fait disparaître ; la v1.1 affirme pourtant qu'il est « rejoué à chaque restauration »	Les données effacées **ressuscitent** ; l'effacement n'est pas démontrable	Registre **répliqué en continu hors de la base** sur un support à écriture seule, conservé plus longtemps que les sauvegardes ; vérification obligatoire avant remise en service
A-08	**Ordre incorrect de la procédure de changement de fournisseur** : le double fonctionnement sur **sondes réelles** (étape 4) précède l'évaluation indépendante (étape 5) et l'approbation (étape 6)	Des données réelles sont envoyées à un moteur **non validé**, en contradiction avec le chapitre 14.4 et le principe fondateur	Réordonner : évaluation indépendante (sur jeu local ou rejeu non réel) → approbation d'activation en mode ombre → double fonctionnement sur sondes réelles
A-11	**Le coffre vit dans le processus applicatif** (`biometric/vault.ts`) : toute exécution de code dans l'application permet de déchiffrer en masse ; le HSM ne protège pas contre un appelant légitime compromis ; aucun quota ni détection de déballage massif	Une seule vulnérabilité applicative expose **toutes** les images et gabarits	**Service biométrique séparé** (processus, identité et réseau distincts, API étroite) ; quotas de déballage par minute et par jour ; alarme sur volume anormal ; journalisation côté HSM
A-14	**Modèle de conservation sans bases légales multiples** : un seul `legalBasisId` par échantillon, aucun lien échantillon ↔ affaire(s) ; une personne peut être partie à plusieurs affaires	Effacement à tort (mise hors de cause dans une affaire alors qu'une autre subsiste) ou conservation illégale	Table de bases (échantillon, affaire ou décision, début, fin) ; **échéance = maximum des bases actives** ; événements issus des statuts de partie (`CLEARED`…) et des issues d'affaire
A-19	**La règle de non-cumul est vide de sens** : un compte n'a qu'**un** rôle (`User.roleId`) ; le risque réel est **une même personne avec deux comptes**, le lien avec l'agent (`Officer`) étant facultatif	Le gardien de clés peut aussi détenir un compte d'enquêteur : la séparation est contournable	Contrainte **au niveau de la personne** (identité RH, matricule, pièce d'identité) : aucun autre compte actif pour un titulaire de profil de gouvernance ; deux gardiens = deux personnes distinctes ; vérification à l'attribution et périodique
A-20	**Aucun épinglage des droits de gouvernance** : les nouveaux droits sensibles peuvent être ajoutés à **n'importe quel rôle non verrouillé** par le circuit existant (deux approbateurs nationaux) ; les nouveaux types d'approbation seraient décidables par tous les titulaires de `approvals:decide`	La séparation des fonctions peut être défaite **sans toucher** aux profils verrouillés	**Épinglage** : liste de droits attribuables seulement à leur profil ; éligibilité par type d'approbation (`governance_approve`) ; test automatisé
A-24	**La collecte du jeu d'évaluation n'est dans aucune phase** : la phase 0 livre un protocole, la phase 4b l'utilise, mais la collecte (personnes réelles, appareils, coffre) n'est planifiée nulle part	Recrée la contradiction « pas de donnée réelle en phase 3 » ; collecte sans cadre	Ajouter une **phase 3b « collecte encadrée »** avec coffre, DPO, consentement, base légale en vigueur, ou intégrer la collecte à la phase 4b sous le même régime

6.3 Anomalie moyenne non validée

N°	Anomalie	Impact	Correction recommandée
A-23	**Critères de phase irréalisables ou non mesurables** : phase 1 exige une cérémonie de clés avec deux gardiens alors que le HSM n'est qu'un adaptateur de développement (acquisition non planifiée) ; phase 5 « 0 erreur d'identité confirmée » et phase 6 « faux positifs confirmés ≤ 0,5 % » ne sont pas mesurables sans vérité terrain ; phase 5 « concordance avec la pratique actuelle » sans référence (aucune pratique biométrique actuelle) ; « ≥ 500 recherches » insuffisant pour un FPIR de 0,1 %	Portes impossibles à franchir honnêtement, ou franchies sur des chiffres sans valeur	Critères fondés sur **échantillonnage avec vérité terrain** (contre-expertise), erreurs signalées et contestées, **intervalles de confiance** ; taille justifiée par l'évaluateur ; HSM en entrée de la phase 1 ou critère reformulé

7. DÉCISION DE LA DIRECTION REQUISE

N°	Point	Décision à prendre
A-10	La **portabilité n'est garantie que si D-03 = option B** (gabarit normalisé + propriétaire + échantillon de référence chiffré) ; le format d'archivage des images n'est pas défini	Confirmer D-03 = B **et** le format d'archivage (ISO/IEC 19794-4 en PNG/WSQ à 500 ou 1000 ppp ; ISO/IEC 19794-5 pour le visage, sans compression destructive)
A-15	**Conflit entre effacement et conservation de preuve** : une capture versée comme pièce à conviction (chaîne de possession en écriture seule) échappe au registre d'effacement	Fixer la **précédence** (la conservation de preuve l'emporte ou non) avec la Justice

A-17	**`attest()` révèle au DUN qu'une personne figure dans le fichier biométrique policier** (inférence sur le statut de suspect ou d'interpellé)	Supprimer par défaut ; n'activer que sur décision écrite, finalité et base légale (D-07)
A-27	**Décisions manquantes** (voir section 8.2)	Ajouter D-17 à D-23

8. Revue des 16 décisions

8.1 Appréciation de chaque décision existante

N°	Décision	Appréciation	Remarque
D-01	Base légale	**Adéquate**	À prendre en premier ; bloque tout le reste
D-02	Hébergement et fournisseur	**À compléter**	Doit être couplée à la décision sur **qui exploite la base et le HSM** (D-23)
D-03	Portabilité	**Critique**	Toute la portabilité en dépend (A-10)
D-04	Profils dédiés	**Adéquate mais insuffisante**	Ne règle pas la séparation au niveau de la personne ni l'épinglage (A-19, A-20)
D-05	Indépendance et effectifs	**À compléter**	Ajouter la qualité de la revue (revue en aveugle, pièges, A-26)
D-06	Conservation et sauvegardes	**À compléter**	Bases multiples (A-14) ; sauvegarde dédiée (A-16)
D-07	Maître de la donnée / DUN	**Recommandation à revoir**	`attest()` (A-17) ; sens des flux (A-18)
D-08	Hors ligne	**Recommandation sans données**	Aucune enquête de connectivité : prérequis D-23
D-09	Périmètre du facial	**Adéquate**	L'interdiction du temps réel nécessite un **texte** juridique
D-10	Seuils et évaluateur	**Adéquate**	Doit fixer la méthode statistique (A-23)
D-11	Galerie initiale	**À compléter**	Exclure ou encadrer les **mineurs** (D-17)
D-12	Voix	**Adéquate**	—
D-13	Budget, HSM, licences	**À compléter**	Niveau d'assurance du HSM (D-21)
D-14	Information des personnes	**Adéquate**	—
D-15	Notification des incidents	**Adéquate**	—
D-16	Gouvernance des portes	**Adéquate**	Doit précéder la phase 0

8.2 Décisions manquantes (à ajouter)

N°	Décision	Pourquoi
D-17	Règles pour les **mineurs** (âge minimal de collecte, interdictions, durée)	Donnée particulièrement sensible ; absente
D-18	**Échanges internationaux** (Interpol, pays voisins) : interdits ou encadrés	Risque de transfert hors territoire contraire à D-02
D-19	**Valeur probante** : usage d'un résultat en procédure	La spec dit « indication » ; la Justice doit fixer les exigences d'admissibilité
D-20	**Statut et indépendance du responsable de la protection des données** (rattachement, moyens)	Sa position conditionne toutes les garanties
D-21	**Niveau d'assurance du HSM** (FIPS 140-3 niveau 3 ou Critères Communs)	Détermine le budget et le fournisseur
D-22	**Accès du parquet** aux données biométriques réelles	Le profil de consultation existe ; son périmètre sur du réel n'est pas défini
D-23	**Qui exploite** la base de données et le HSM (informatique de la police, prestataire) et **enquête de connectivité** des provinces	Responsabilité d'exploitation (A-01) ; fondement de D-08

9. Checklist de revue indépendante recommandée (remplace les 14 points de l'auteur)

Les 14 points de la v1.1 sont conservés dans leur principe, mais **sont insuffisants et ne constituent pas une revue indépendante**. Checklist recommandée pour la v1.2 :

1. Le compte applicatif n'est **ni propriétaire, ni superutilisateur** ; les tables d'historique refusent `UPDATE` et `DELETE` à ce compte (test d'attaque).
2. L'**empreinte de chaque décision** est dans le journal chaîné ; un écart est détecté.
3. L'empreinte de tête est **exportée hors de la base** vers un support immuable, vérifiée par un tiers.

TECHNOTOPIA

4. Une **restauration** exige un double contrôle, vérifie la chaîne et les empreintes externes, rejoue un registre d'effacement **conservé hors base**.
5. Le **coffre** est un service séparé avec quotas et alarmes de déballage ; la fuite d'un processus applicatif ne permet pas de déchiffrer en masse.
6. Le **double contrôle des clés** est natif au HSM (quorum M sur N), avec séparation des rôles HSM.
7. Le chiffrement lie chaque chiffré à son enregistrement (**AAD**) ; le cycle de vie complet (compromission, panne, séquestre, départ d'un gardien) est décrit et testé.
8. La **séparation des fonctions** s'applique à la **personne**, pas au compte ; les droits de gouvernance sont **épinglés** ; l'éligibilité des approbateurs est propre à chaque type.
9. La conservation gère des **bases légales multiples** ; la précédence preuve / effacement est écrite.
10. La procédure de **changement de fournisseur** respecte l'ordre évaluation → approbation → double fonctionnement ; un **second moteur réel** a été testé.
11. La fédération **n'expose pas** le statut d'une personne au DUN ; scissions et mode dégradé sont décrits.
12. Chaque phase a des critères **mesurables avec vérité terrain**, un arrêt et un retour arrière **réalisable** (énumérations, clés comprises) ; la **collecte** du jeu d'évaluation est planifiée.
13. La **revue humaine** est protégée contre le biais d'automatisation (aveugle, pièges, filigrane, indicateurs).
14. Les décisions D-01 à D-23 sont **prises ou planifiées**, et le registre des risques est complet.

10. Revue des 10 risques résiduels

N°	Risque de la v1.1	Appréciation de la revue
R-01	Deux chemins de chiffrement	**Acceptable** ; garde de non-modification de `crypto.ts` confirmée
R-02	Contournement des déclencheurs par un superutilisateur	**Sous-évalué : Élevé à Critique** (la situation actuelle est un superutilisateur applicatif : A-01)
R-03	Rareté des relecteurs	**Acceptable** mais à quantifier (nombre par province)
R-04	Fenêtre de 35 jours dans les sauvegardes	**À reconsidérer** : le registre d'effacement n'est pas protégé (A-05)
R-05	Perte de précision des gabarits normalisés	**Acceptable** si un second moteur réel est testé (A-09)
R-06	Impact d'une fuite accru par les images	**Élevé** ; non atténué tant que le coffre est dans l'application (A-11)
R-07	Spécifications du DUN inconnues	**Acceptable**
R-08	Faux rapprochements de plaques	**Acceptable**
R-09	Cadre juridique non confirmé	**Bloquant** (rien ne peut démarrer sans lui)
R-10	Dérive documentaire	**Acceptable**

Risques absents du registre : falsification par un administrateur de base de données ; restauration comme vecteur ; oracle de déballage de clés ; **atteinte aux droits par faux positif (interpellation injustifiée), risque principal du système** ; biais démographiques du visage ; défaillance ou faillite du fournisseur ; panne du HSM ; divulgation indirecte au DUN ; biais d'automatisation des relecteurs.

11. Suite recommandée

Ordre de traitement pour la **version 1.2** (document seulement) :

1. Séparation des rôles de base de données et exploitation (A-01, D-23).
2. Chaînage du contenu des tables biométriques et ancrage externe de l'empreinte de tête (A-02, A-03).
3. Restauration à double contrôle et registre d'effacement hors base (A-04, A-05).
4. Coffre en service séparé, quotas, quorum du HSM, cycle de vie complet des clés (A-11, A-12, A-13).
5. Séparation au niveau de la personne et épinglage des droits (A-19, A-20, A-21).
6. Modèle de bases légales multiples et précédence preuve / effacement (A-14, A-15).
7. Réordonnancement de la procédure de changement de fournisseur et critère de second moteur réel (A-08, A-09).
8. Réécriture des critères de phases, phase 3b, retour arrière réaliste (A-23, A-24, A-25).
9. Décisions D-17 à D-23, ajustement de D-03 et D-07 (A-10, A-17, A-27).
10. Registre des risques complet et checklist de la section 9 (A-28, A-29).

Aucune implémentation n'est autorisée tant que la version 1.2 n'a pas été examinée par une **revue humaine externe** et approuvée par la Direction.

TECHNOTCHAD

12. Annexe — Détail des anomalies restantes

N°	Gravité	Anomalie	Impact	Correction recommandée	Statut
A-03	Majeure	L'empreinte de tête est « exportée quotidiennement » sans destinataire ni mécanisme	La suppression des dernières lignes et la restauration d'une ancienne base passent inaperçues	Support externe immuable, horodatage par un tiers, fréquence, vérificateur indépendant, alerte	Sous réserve
A-06	Majeure	`isDemo` n'est pas listé parmi les colonnes immuables ; `requestedById` est facultatif pour les anciennes lignes	Un `UPDATE` de `isDemo` rouvre la modification d'une décision ; un demandeur nul contourne « ≠ demandeur »	Liste exhaustive des colonnes immuables ; contrainte `isDemo = faux ⇒ requestedById non nul` ; interdiction de changer `isDemo`	Sous réserve
A-07	Majeure	`BiometricControl` reste modifiable et a ses propres champs de revue, « alimentés aussi » dans `BiometricReview`	Deux sources de décision (contradiction avec C-07) et surface d'écrasement	Champs de décision du contrôle en lecture seule dans le chemin réel, dérivés de `BiometricReview` ; déclencheurs sur le statut	Sous réserve
A-09	Majeure	La phase 2 teste le changement de fournisseur entre **deux simulateurs** de même sémantique	Ne prouve rien sur la compatibilité réelle (formats, minuties, perte de précision)	Critère : ré-enrôlement vers un **second moteur réel** (au moins bac à sable), écart de précision mesuré ≤ seuil ; clause contractuelle ; exercice annuel réel	Sous réserve
A-10	Majeure	La portabilité n'est garantie que si D-03 = B ; format d'archivage des images non défini	Garanties du chapitre 9 caduques selon la décision	Voir section 7	Décision requise
A-12	Majeure	Le « double contrôle » des clés est applicatif (commandement + DPO)	L'administrateur du HSM ou du serveur le contourne	Quorum natif du HSM (M sur N), rôles HSM séparés, niveau d'assurance (D-21)	Sous réserve
A-13	Moyenne	Cycle de vie HSM incomplet : compromission, panne, migration, séquestre, départ d'un gardien, agilité cryptographique ; pas de données authentifiées associées dans `bv1`	Substitution de chiffrés entre lignes ; reprise impossible en cas d'incident	Chapitre « cycle de vie des clés » ; AAD (identifiant, `kekId`, version) obligatoire	Sous réserve
A-15	Moyenne	Conflit effacement / preuve non arbitré	Copie d'échantillon dans `Evidence` hors registre d'effacement	Voir section 7	Décision requise
A-16	Moyenne	Sauvegarde dédiée aux gabarits supposée mais le dispositif actuel sauvegarde toute la base d'un bloc	Soit la sauvegarde globale est limitée à 35 jours, soit les gabarits sont conservés plus longtemps	Schéma ou base dédiée aux gabarits ; les autres sauvegardes les **excluent** ; test de restauration	Sous réserve
A-17	Majeure	Voir section 7	—	—	Décision requise
A-18	Moyenne	Fédération : sens des flux, scission, dérivation des pseudonymes, indisponibilité du DUN	Interopérabilité non figée	Matrice de flux ; procédure de scission avec revue ; dérivation par HMAC avec clé du coffre ; mode dégradé	Sous réserve
A-21	Moyenne	L'administrateur de sécurité (peut attribuer des rôles opérationnels sans les détenir) pourrait s'auto-désigner gardien ou DPO	Séparation défaite à l'attribution	Attribution **uniquement** par demande approuvée par commandement national et DPO ; interdiction à l'administrateur de sécurité	Sous réserve
A-22	Moyenne	Tests à contenu exact non listés ; la scission de visibilité change le contenu de `GET /history/{id}` pour les lignes réelles	Tests rouges ; contrat de réponse en réalité modifié	Liste des tests à adapter ; champ `visibility` explicite ; test de contrat	Sous réserve
A-25	Moyenne	« Migrations additives annulées » irréalisable pour les énumérations PostgreSQL ; tables avec données réelles ; retour de ré-enveloppement non décrit	Retour arrière impossible ou destructeur	« Avancer seulement » pour les énumérations (valeurs inertes) ; retour par désactivation ; procédure de retour de ré-enveloppement	Sous réserve

TECHNOTHAD

A-26	Moyenne	Biais d'automatisation : l'indépendance nominale ne garantit pas la qualité	Validation sans examen	Revue en aveugle (sans score), **échantillons-pièges**, temps minimal, filigrane du relecteur, formation et recertification, indicateurs (taux d'infirmation, accord inter-relecteurs)	Sous réserve
A-27	Moyenne	Décisions manquantes	Voir section 8.2	D-17 à D-23	Décision requise
A-28	Moyenne	Registre de risques incomplet et sous-évalué	Pilotage faussé	Section 10	Sous réserve
A-29	Mineure	La checklist de 14 points est rédigée par l'auteur et omet les points ci-dessus	Fausse assurance	Checklist de la section 9	Sous réserve
A-30	Mineure	Imprécisions : `BiometricMatch.subjectId` vs `personId` ; sceau de `BIOMETRIC_MODE` (qui peut le changer ?) ; « sans téléchargement » n'empêche pas la capture d'écran ; durée de conservation des clés d'idempotence	Ambiguïtés d'implémentation	Préciser ; filigrane ; contrôle d'intégrité de la configuration	Sous réserve

Rappel. Cette revue n'a modifié aucun code, aucune migration, aucune donnée ni configuration ; les marqueurs DEMO sont intacts ; aucun moteur réel n'est connecté ; aucun commit n'a été poussé.

TECHNOTCHAD